

Sistemi Operativi 1

AA 2024/2025

Protezione e Sicurezza

Proprietà di sicurezza

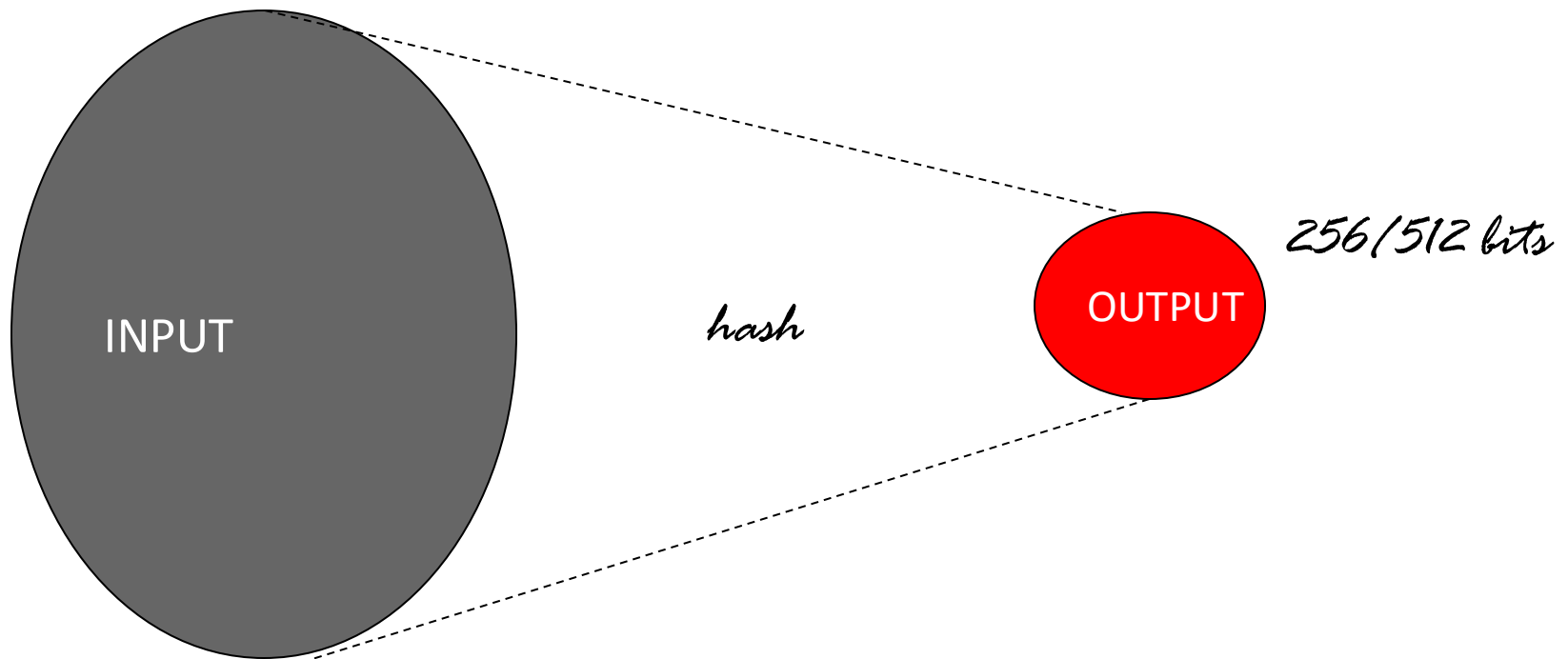
- **Integrità** = garantire che il file non sia stato modificato in modo non autorizzato
- **Segretezza/Confidenzialità** = garantire che il dato possa essere letto solo da chi è autorizzato
- **Autenticazione** = che l'utente sia effettivamente chi dice di essere

Primitive di crittografia

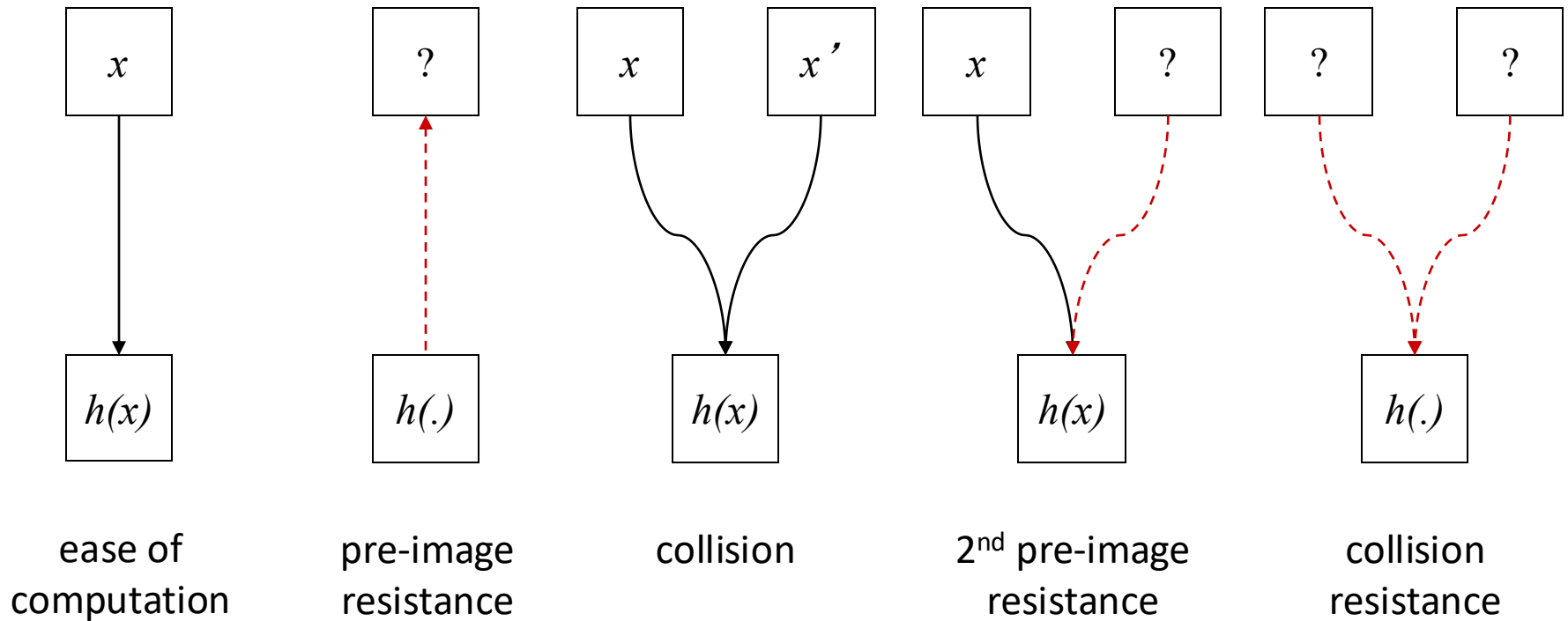
- Hash crittografiche
- Cifratura a chiave simmetrica
- Cifratura a chiave pubblica

Hash crittografiche

- Funzione con output di lunghezza fissa
 - Mappa stringhe di qualsiasi dimensione a stringhe di lunghezza fissa



Proprieta' delle hash crittografiche



Hash crittografiche - applicazione

- Esempi di hash SHA-512, Keccak (nuovo standard)
- Nella distribuzione di SW online per controllarne la sua integrità

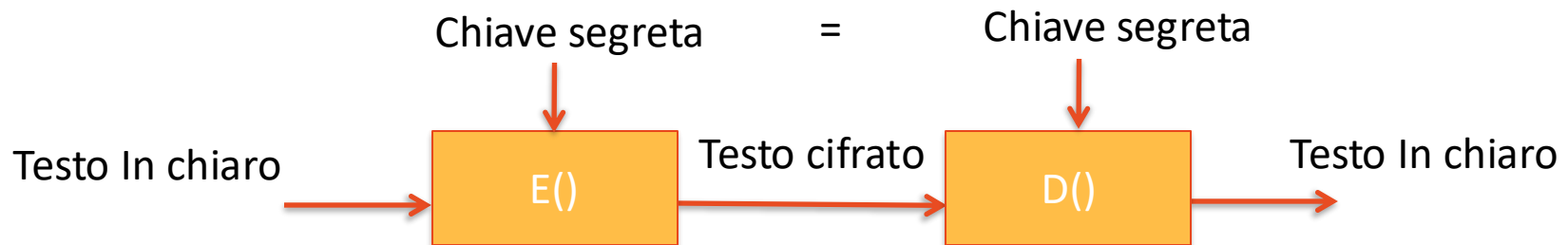
Crittografia a chiave simmetrica



Scytale, 700 BC

Crittografia a chiave simmetrica

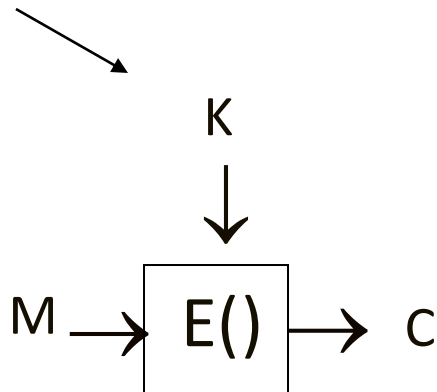
- La sola forma di crittografia esistente fino alla fine degli anni '70
- $E()$, funzione di crittazione, $D()$ funzione di decrittazione. Inverse.



Crittografia a chiave simmetrica

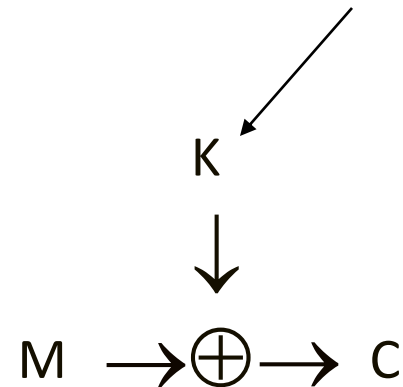
- Cifrari a flusso (stream)
- Cifrari a blocco

128-256 bits long



block cipher

very long and never reused key stream



$E() = \text{XOR}$

stream cipher

Esempi di cifrari moderni

RC4 $\Rightarrow$ SSL/TLS, browsers

AES cifrario a blocco standard

Applicazioni

- Cifratura di file systems
- Cifratura del traffico di rete (SSL, IPSEC, etc.)

Crittografia a chiave pubblica (asimmetrica)

- Inventata (per tutti) da Diffie e Hellman nel 1976.
- Ogni utente ha due chiavi **diverse** una **chiave pubblica per la cifratura** e una **chiave privata/segreta per la decrittazione**
- Dalla chiave pubblica non si può derivare la chiave privata. Corrispondenza unica tra le due chiavi
- La chiave è chiamata pubblica perchè può essere nota a tutti. Solo una delle due chiavi va mantenuta privata.

Crittografia a chiave pubblica

- Assunzioni:
 - Ogni utente ha la sua coppia di chiavi : pubblica e privata/segreta
 - Ogni utente conosce tutte le chiavi pubbliche
 - Solo il proprietario conosce la sua chiave segreta/privata

Crittografia a chiave pubblica

- Assunzioni:
 - Ogni utente ha la sua coppia di chiavi : pubblica e privata/segreta
 - Ogni utente conosce tutte le chiavi pubbliche
 - Solo il proprietario conosce la sua chiave segreta/privata

Alice's secret key = SK_A

Alice's public key = PK_A

Bob's public key = PK_B

Bob's secret key = SK_B

Bob's public key = PK_B

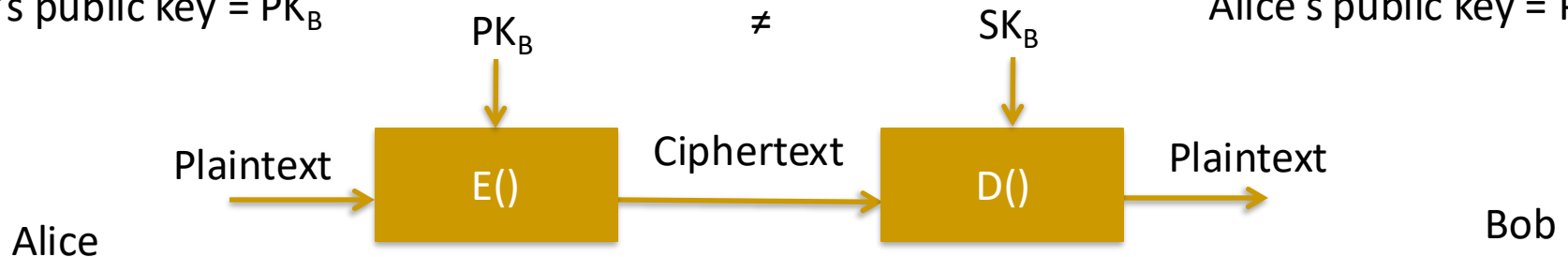
Alice's public key = PK_A

Crittografia a chiave pubblica

- Assunzioni:
 - Ogni utente ha la sua coppia di chiavi : pubblica e privata/segreta
 - Ogni utente conosce tutte le chiavi pubbliche
 - Solo il proprietario conosce la sua chiave segreta/privata

Alice's secret key = SK_A
Alice's public key = PK_A
Bob's public key = PK_B

Bob's secret key = SK_B
Bob's public key = PK_B
Alice's public key = PK_A



$E()$ and $D()$ sono due funzioni diverse

Firma digitale

Alice's secret key = SK_A (Chiave di firma)
Alice's public key = PK_A (Chiave di verifica)
Bob's public key = PK_B

Bob's secret key = SK_B
Bob's public key = PK_B
Alice's public key = PK_A

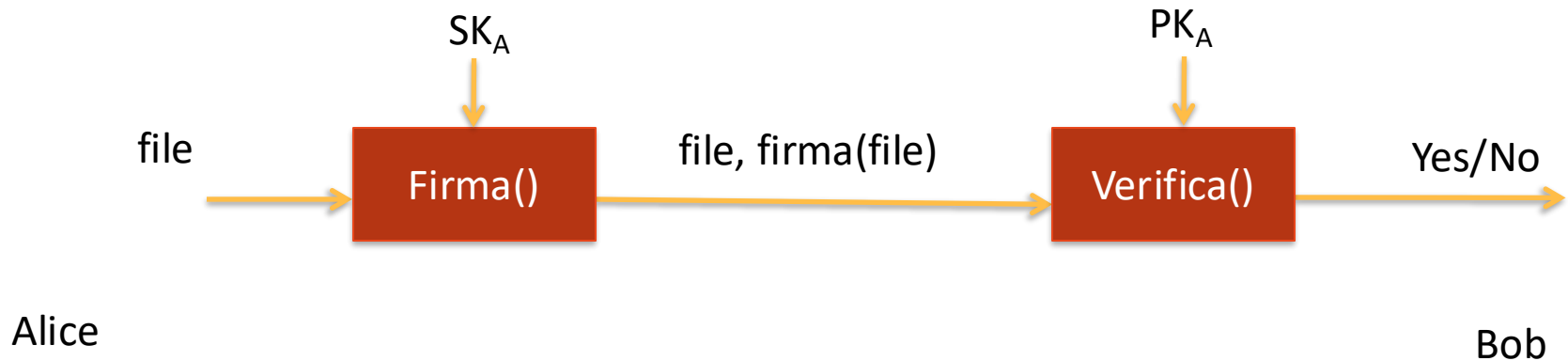
Alice

Bob

Firma digitale

Alice's secret key = SK_A (Chiave di firma)
Alice's public key = PK_A (Chiave di verifica)
Bob's public key = PK_B

Bob's secret key = SK_B
Bob's public key = PK_B
Alice's public key = PK_A

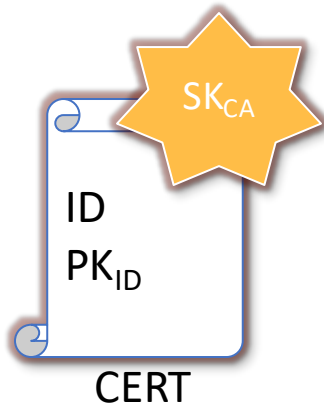


Esempi di algoritmi a chiave pubblica

- RSA, DSA, basati sulle curve ellittiche per smartcard e ambienti embedded.

Certificato Digitale

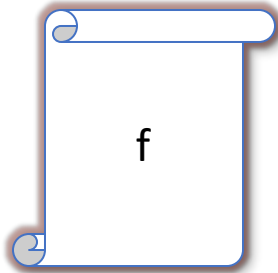
- Certifica che una chiave pubblica appartiene (e identifica nel cibernazio) ad una specifica entità (es. persona, server, sito web, device driver, etc.)



$Sign = Firma(CERT, SK_{CA})$

$Verifica(CERT, Sign, PK_{CA}) = True/False$

Chaining



$\text{Sign} = \text{Firma}(f, \text{SK}_1)$

$\text{Verifica}(f, \text{Sign}, \text{PK}_1) = \text{True/False}$

$\text{Sign}' = \text{Firma}(\text{Sign}, \text{SK}_2)$

$\text{Verifica}(\text{Sign}, \text{Sign}', \text{PK}_2) = \text{True/False}$

$\text{Sign}'' = \text{Firma}(\text{Sign}', \text{SK}_3)$

$\text{Verifica}(\text{Sign}', \text{Sign}'', \text{PK}_3) = \text{True/False}$

....

....

$\text{Sign}^n = \text{Firma}(\text{Sign}^{n-1}, \text{SK}_n)$

$\text{Verifica}(\text{Sign}^{n-1}, \text{Sign}^n, \text{PK}_n) = \text{True/False}$

LOGIN - AUTENTICAZIONE UTENTI

Tipi di autenticazione

- Basata su quello che l'utente conosce (es. pin, password)
- Basata su quello che l'utente ha (es. chiavetta usb, smartcard)
- Basata su quello che l'utente è o fa (es. Biometrie fisiologiche o comportamentali)

Autenticazione degli utenti

- Fatta da due operazioni:
 - identificazione (login). Utente annuncia chi è
 - Autenticazione vera e propria dove si verifica (password) che è proprio chi dice di essere

Scelta delle password (teorica)

- Regole da seguire:
 - Almeno 8 caratteri, un carattere per ognuna di queste categorie:
 - Lettere minuscole
 - Lettere maiuscole
 - Cifre numeriche
 - Caratteri speciali: , . ; : - _ # [] ? ^ + * ' ` ~ { } ()

Scelta delle password (reale)

- Alcune statistiche
 - Morris-Thompson, 1979 – 86% delle password identificate. Password raccolte in vari sistemi Unix dell'epoca
 - Klein, 1990 - 25% delle password identificate. Password raccolte da vari sistemi Unix in UK/USA
 - Kabay, 1997 - 82% delle password identificate. Password utilizzate nel financial district di Londra
- _Password_1, _Password_2, _Password_3.....

Memorizzazione password

- Unix

$\text{crypt} = 25 \times \text{DES}(\text{salt}, 0, \text{pwd}) = c$

$|c| = 64\text{bits}$

$|\text{pwd}| = 56\text{bits}$

$|\text{salt}| = 12\text{bit}$

- Unix

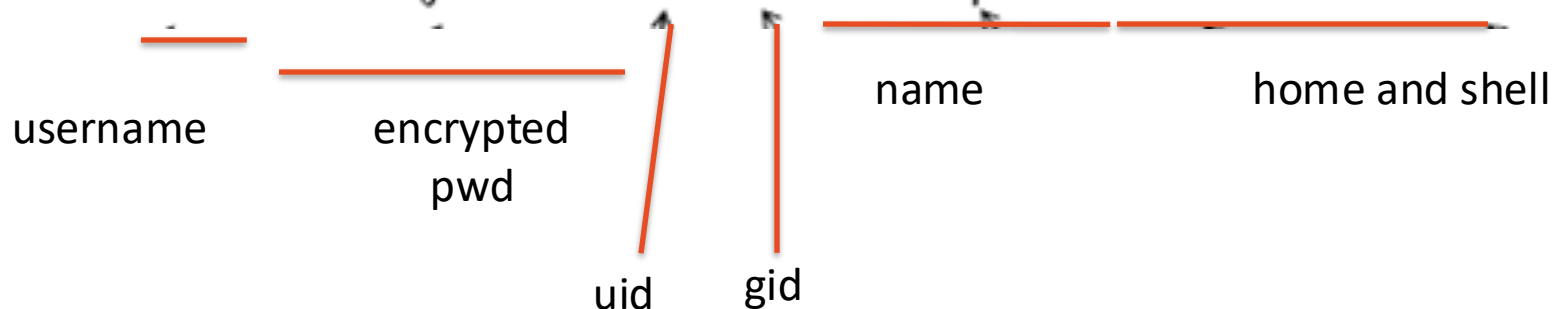


Memorizzazione delle password

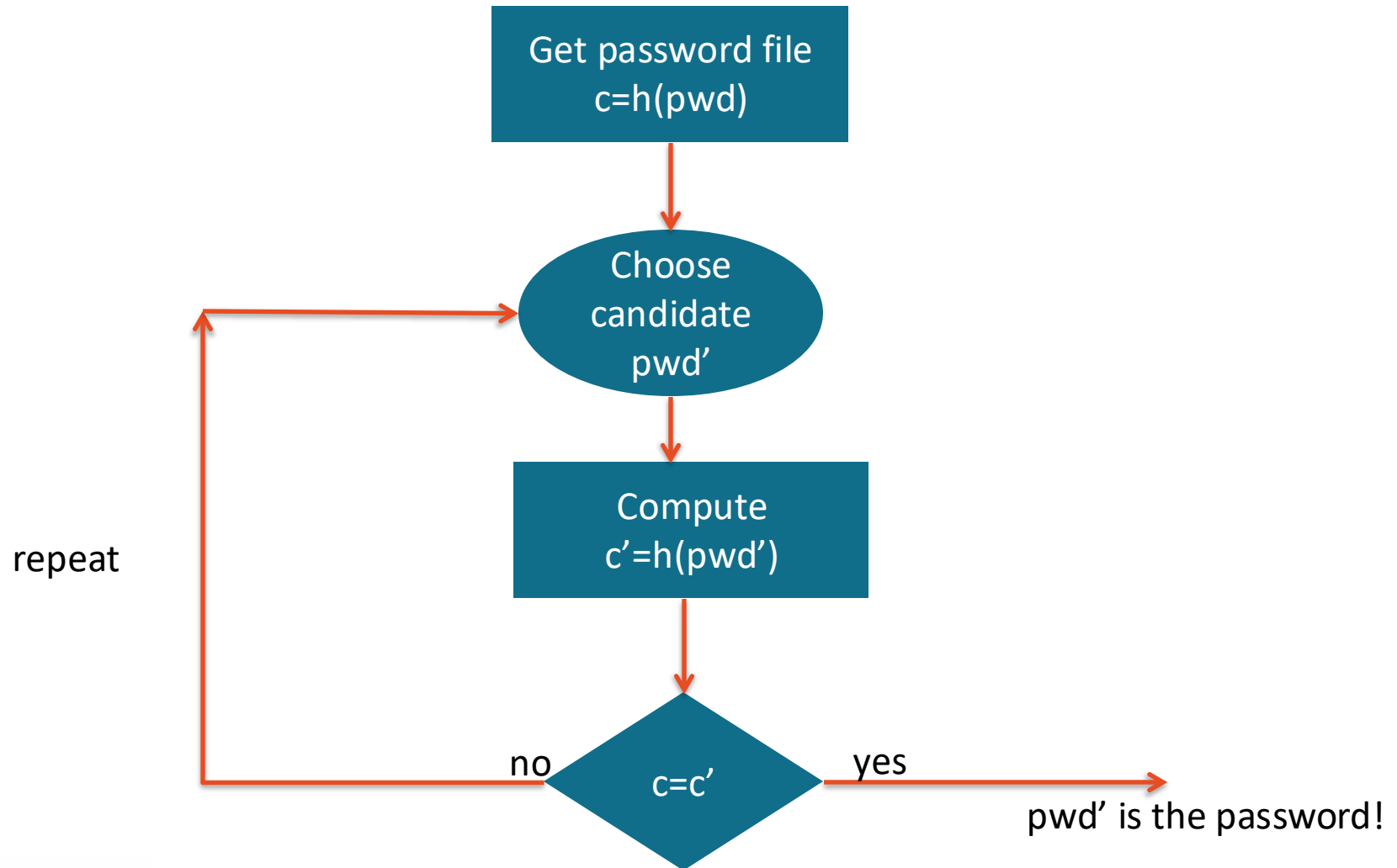
- Es. unix

File `/etc/passwd`

```
root:fi3sED95ibqR6:0:1:System Operator:/:/bin/ksh
daemon*:1:1::/tmp
uucp:OORoMN9FyfNE:4:4:/var/spool/uucppublic:/usr/lib/uucp/uucico
ciro:eH5/.mj7NB3dx:181:100:Ciro Esposito:/u/ciro:/bin/ksh
```



Attacco del dizionario (off-line)



Autenticità del sistema operativo

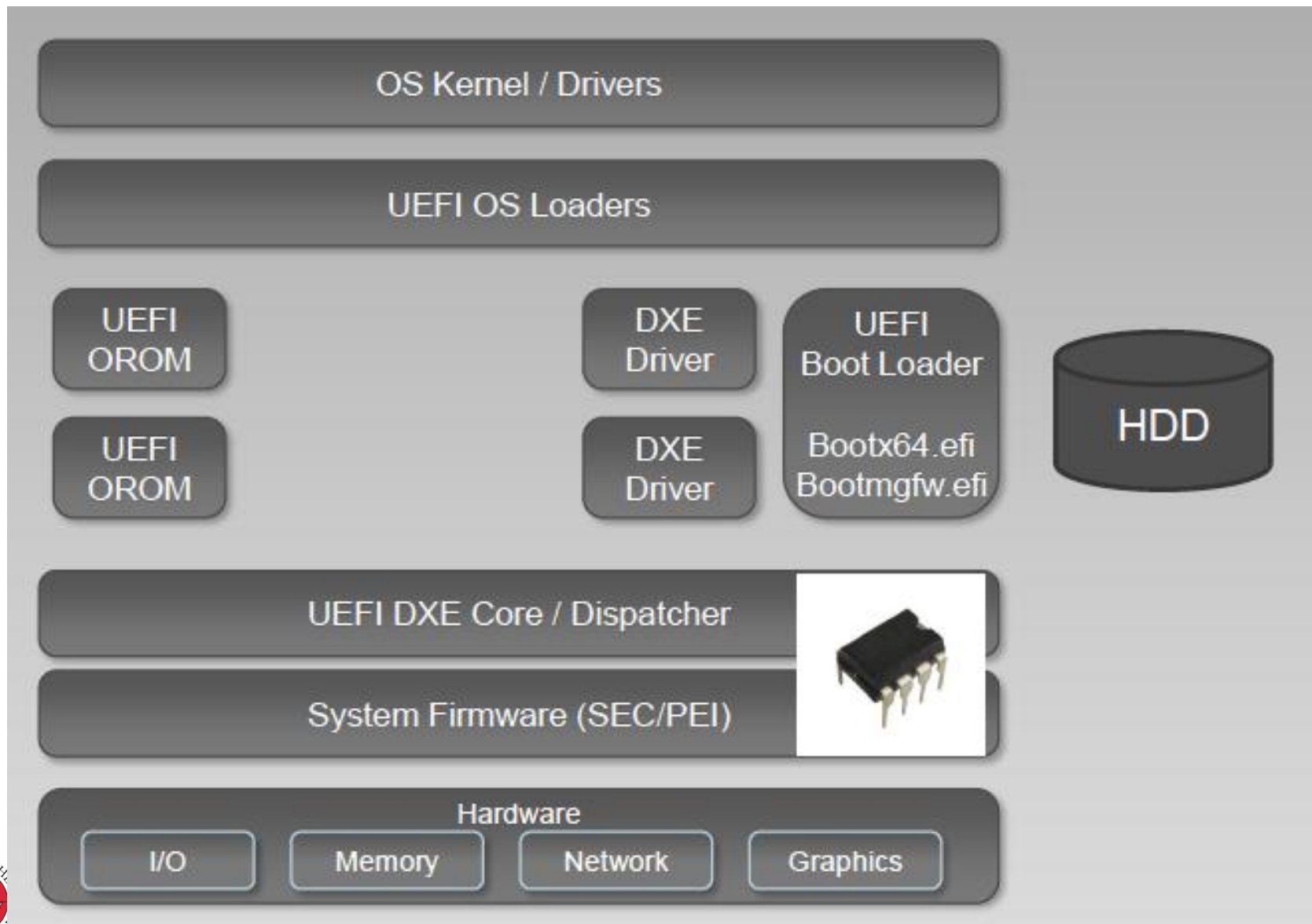
- Problema: come essere sicuri dall'autenticità del kernel caricato in memoria al momento di avvio?
- Problema di integrità e autenticità

TRUSTED BOOT

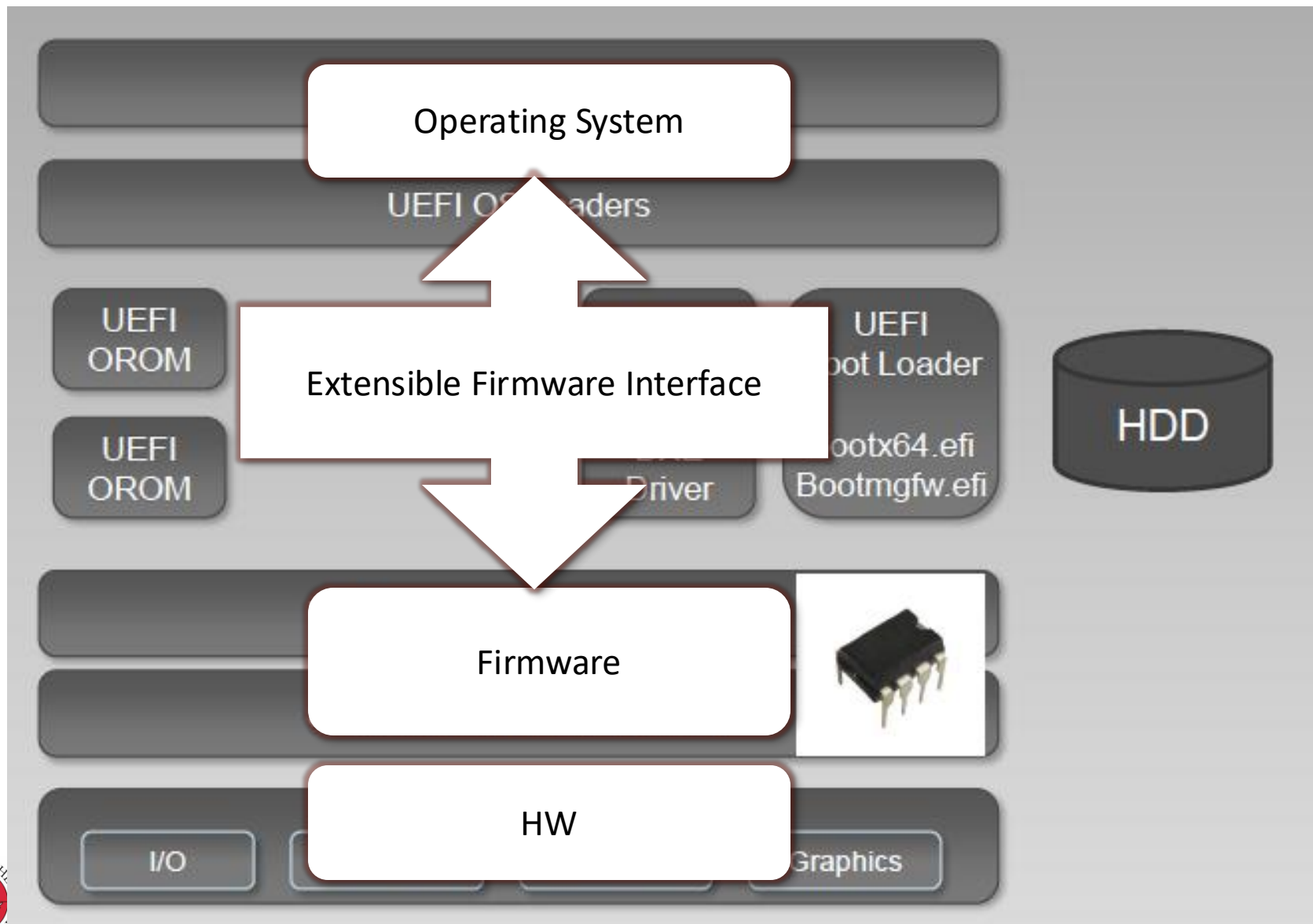
BIOS

- Basic Input - Output System for original IBM PC/XT and PC/AT
- Originated in 1980s
- Based on 8086 architecture. It's firmware in ROM
- A group of clearly defined OS-independent interface for hardware
 - Int10 for Video service
 - Int13 disk service
 - Int16 keyboard service
 - Int18 BIOS ROM loader
 - Int19 bootstrap loader
- POST (Power-On Self Test) HW checks before loading the program that load the OS
- Availability of MS-DOS outside of IBM allowed applications to run equally well across different brands of box "PC clones".
- Controlli fatti per valutare correttezza configurazione ma non a scopi di sicurezza.

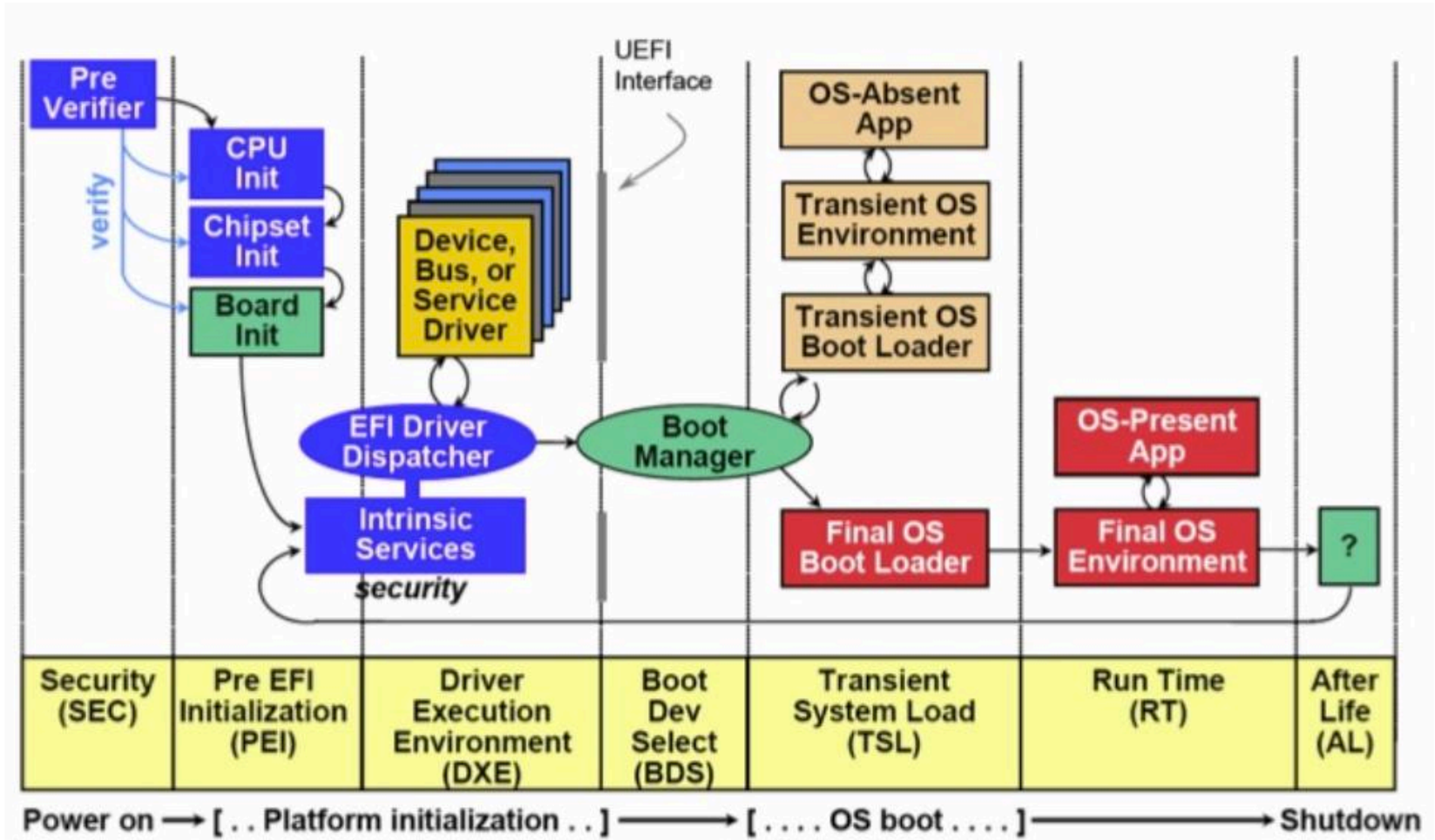
UEFI: Unified Extensible Firmware Interface



UEFI: Unified Extensible Firmware Interface



Secure UEFI Boot



OS
Secure
Boot

Secure UEFI Boot

Signed
BIOS
Update

OS Driver

OS Driver

OS Kernel / Early Launch Anti-Malware (ELAM)

UEFI OS Loaders (winload.efi, winresume.efi)

UEFI
OROM

UEFI
App

DXE
Driver

UEFI
Boot Loader

UEFI
OROM

UEFI
App

DXE
Driver

Bootx64.efi
Bootmgfw.efi

UEFI DXE Core / Dispatcher

System Firmware (SEC/PEI)

Hardware

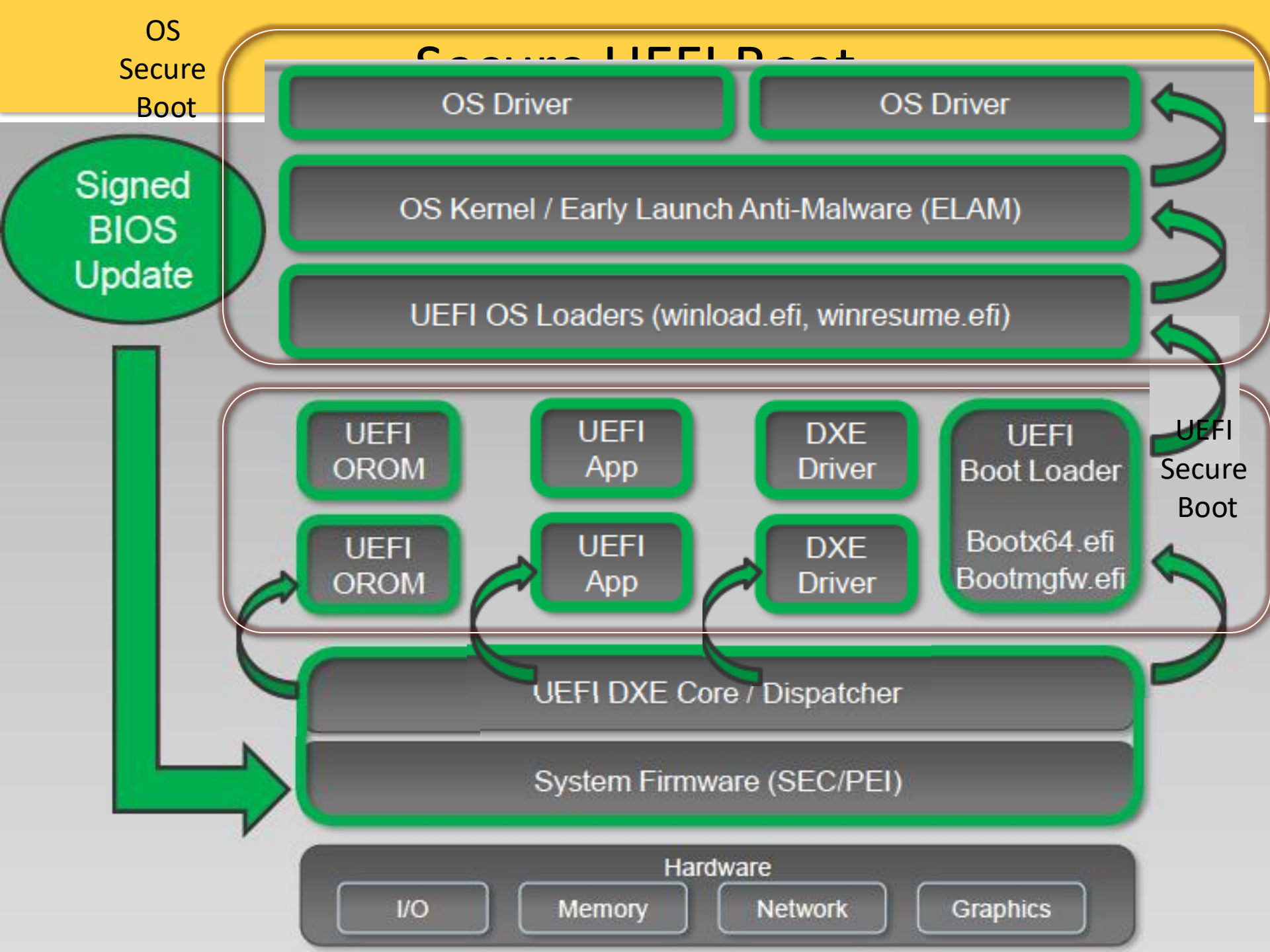
I/O

Memory

Network

Graphics

UEFI
Secure
Boot



Platform Key (PK) (PC Vendor)

- Verifies KEKs
- Platform Vendor's Cert

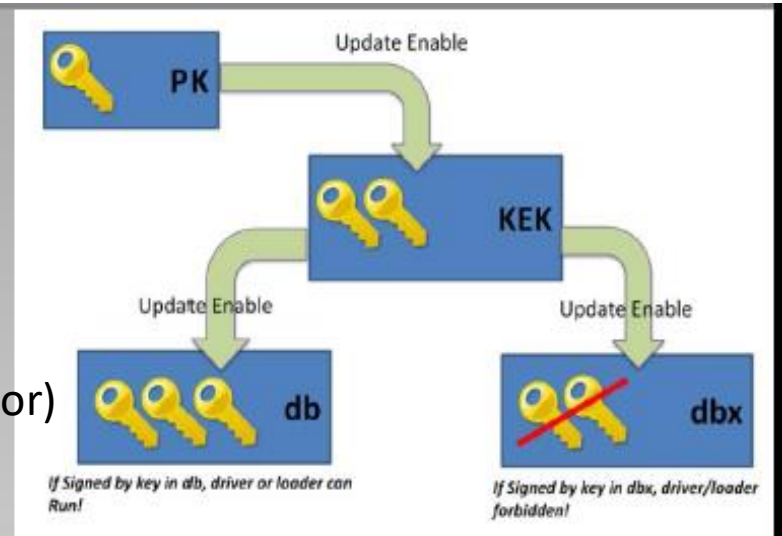
Key Exchange Keys (KEKs) (OS Vendor)

- Verify db and dbx
- Earlier rev's: verifies image signatures

Authorized Database (db)

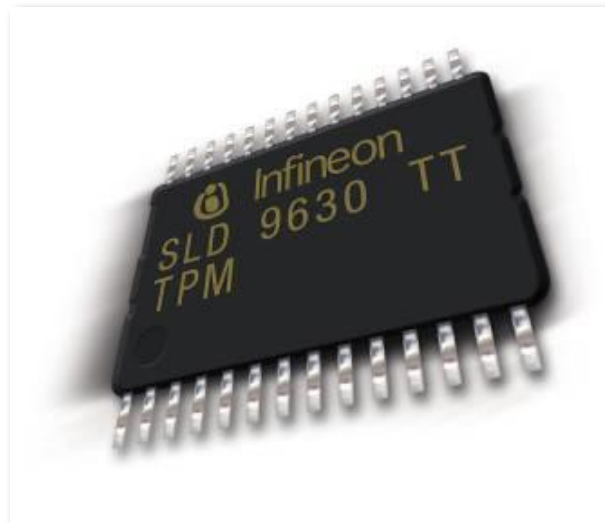
Forbidden Database (dbx)

- X509 Certificates, image SHA1/SHA256 hashes of allowed and revoked images



Trusted Platform Module (TPM)

- Un chip “sicuro” integrato sulla scheda madre
- Fornisce generazione e memorizzazione sicura delle chiavi crittografiche. Implementa primitive crittografiche
- Di fatto è un co-processore “trusted” separato



CIFRATURA DISCO

Cifratura del disco

- La partizione di OS cifrata contiene
 - OS
 - Swap
 - File temporanei
 - File System
 - File di ibernazione
- Dove è la chiave di cifratura?
 1. SRK (Storage Root Key) è memorizzata nella TPM
 2. SRK usata per cifrare la chiave di cifratura dell'intero volume (FVEK: Full Volume Encryption Key) protetta da un PIN
 3. FVEK memorizzata (cifrata) sul HDD nel volume di OS

